

TASK-7

HTTP/2 Rapid Reset Attack

Submitted by: Mark Alexander Varghese

The most significant DDoS incident in recent years was the exploitation of the HTTP/2 Rapid Reset zero-day vulnerability (CVE-2023-44487) in late 2023. The attack was highly impactful because it represented a new, sophisticated method that was highly effective and difficult to mitigate with existing defenses.

Target

The attacks targeted major cloud service providers, their customers, and large technology firms that rely on the HTTP/2 protocol. Companies like Google, Cloudflare, and Amazon Web Services were all affected and worked together to disclose the vulnerability and share mitigation strategies. The attacks were not aimed at a single entity but were a broad campaign against the internet's core infrastructure.

Technology Used

The attack exploited a critical flaw in the HTTP/2 protocol's stream multiplexing feature. The attacker would open an HTTP/2 connection and immediately send a large number of requests. However, instead of waiting for a response, the attacker would immediately send a RST_STREAM frame to cancel each request. This process was repeated at an incredible rate.

So basically a RST_STREAM frame is a control frame in the protocol that allows one side of connection(client or server) to immediately terminate a specific stream.

The malicious part of this was that the server would still have to do significant work to process and then cancel each request, such as parsing headers and allocating memory. Meanwhile, the attacker's botnet required minimal resources to send these "request-and-cancel" commands. This created a massive cost asymmetry, allowing a relatively small botnet to generate a record-breaking volume of requests Google reported seeing attacks peak at 398 million requests per second.

Attacker's Motive

The specific motives for the attacks were not officially confirmed. However, the sophistication of the attack and the exploitation of a zero-day vulnerability suggest it was carried out by a highly skilled actor, likely a state-sponsored group or a sophisticated cybercriminal organization. The goal was to cause widespread disruption and demonstrate a new and powerful attack capability. This type of incident is often a way for attackers to test their new tools or to be used as a distraction for other, more targeted attacks.

Overall Impact

The HTTP/2 Rapid Reset attacks had a profound impact:

- **Unprecedented Scale:** The attacks shattered previous records for application-layer DDoS attacks, demonstrating a new level of threat.
- **Widespread Instability:** The sheer volume of the attacks caused "intermittent edge instability" for some of the world's largest internet providers, leading to performance degradation and outages for their customers.

Defensive Strategies

Standard DDoS defenses were largely ineffective against this attack. A multi-layered approach was required to mitigate it:

- **Rapid Patching:** The most critical defense was the swift development and deployment of patches by software vendors to fix the underlying HTTP/2 vulnerability.
- **Behavioral Anomaly Detection:** Traditional rate-limiting was insufficient as the attack traffic often looked like a high volume of legitimate, albeit canceled, requests. Defenses needed to use advanced behavioral analysis and machine learning to detect the abnormal pattern of rapid RST_STREAM commands and close the offending connections.